

Mediroza General Hospital

Web Application Penetration Testing Report

Authorized Security Assessment

Educational / Training Environment

Target:	https://medirozahospital.com
Assessment Type:	Web Application Penetration Test
Tester:	Prabhat Shinde
Date:	03 October 2026
Purpose:	Educational Security Assessment

Authorization Notice:

This report documents activity performed within an authorized security-testing environment. The techniques described in this report must not be applied to systems without explicit written permission from the system owner.

Contents

1	Introduction	2
2	Scope	2
3	Methodology	2
4	Reconnaissance	3
5	Authentication Testing	4
5.1	Finding 1 – Username Enumeration	5
6	SQL Injection and Authentication Bypass	6
6.1	Finding 2 – SQL Injection / Authentication Bypass	6
7	Patient Reports	7
7.1	Finding 3 – Patient Report Access	7
8	PDF Password Analysis	7
8.1	Finding 4 – Weak PDF Passwords	8
9	PDF Metadata Analysis	8
9.1	Finding 5 – Sensitive PDF Metadata	9
10	Investigation of the /old/ Directory	10
10.1	Finding 6 – Exposed Legacy Backup	11
11	Database Backup Analysis	12
11.1	Finding 7 – Confidential Information Exposure	13
12	Evidence Correlation	13
13	Findings Summary	14
14	Recommendations and Remediation	14
14.1	Authentication	14
14.2	Authentication Error Messages	14
14.3	Patient Documents	15
14.4	PDF Passwords	15
14.5	PDF Metadata	15
14.6	Directory Listing and Backups	15
15	Lessons Learned	15
16	Conclusion	15
17	Authorization and Responsible Testing	16

1 Introduction

This assessment was carried out as part of an authorized penetration testing exercise against the Mediroza General Hospital web application.

The main objective was to understand how the application behaves from an attacker's perspective, identify security weaknesses, validate the findings, and document their potential impact.

The assessment started with basic reconnaissance and gradually moved towards authentication testing, document analysis, metadata examination, and investigation of legacy resources exposed by the application.

One of the most interesting aspects of the assessment was that several findings were connected. Information discovered in a PDF eventually provided a clue that led to an exposed database backup.

2 Scope

The assessment focused on the following web application:

- **Target:** <https://medirozahospital.com>

Testing was performed only within the authorized environment provided for the exercise.

3 Methodology

The assessment followed a step-by-step approach rather than immediately attempting exploitation.

The general process was:

1. Reconnaissance
2. Identify exposed application paths
3. Investigate authentication
4. Test application input handling
5. Validate discovered vulnerabilities
6. Examine accessible documents
7. Analyze document metadata
8. Follow clues discovered during the investigation
9. Investigate legacy resources
10. Document findings and recommendations

The overall investigation can be summarized as:

Reconnaissance → Enumeration → Authentication Testing → Document Analysis
→ Evidence Correlation

4 Reconnaissance

The first step was to understand what the website was exposing.

The site's `robots.txt` file was inspected using:

```
curl -i https://medirozahospital.com/robots.txt
```

The following screenshot shows the observed `robots.txt` content.

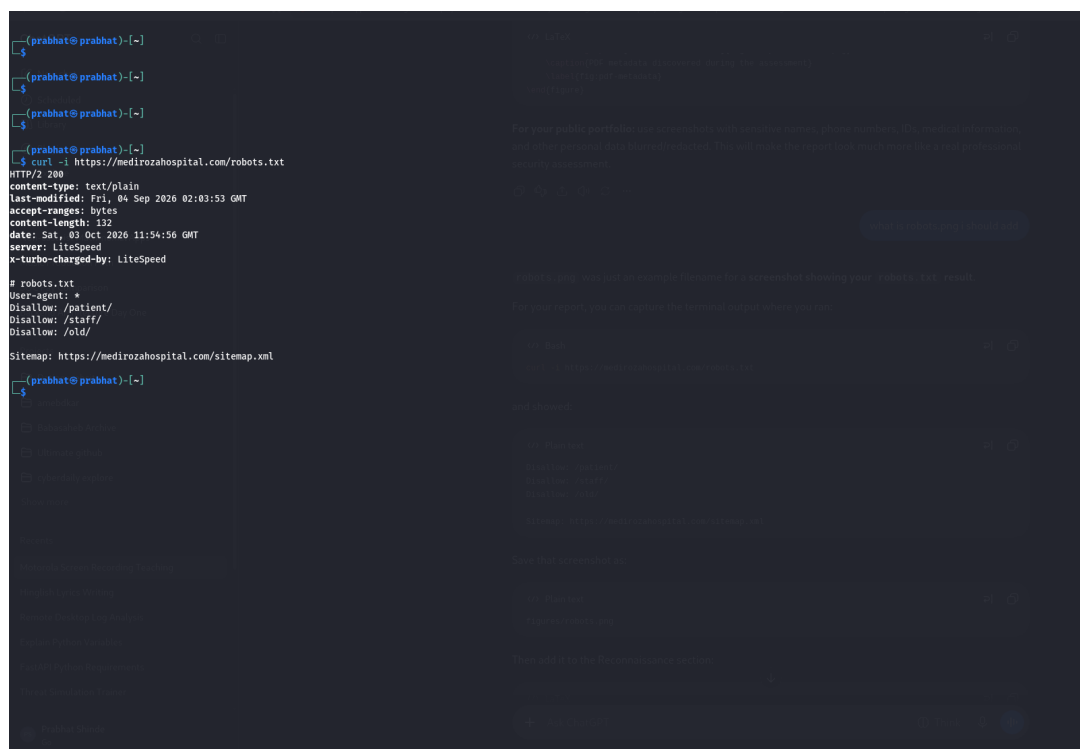


Figure 1: robots.txt revealing additional application paths

The file contained the following paths:

- `/patient/`
- `/staff/`
- `/old/`
- Sitemap: `https://medirozahospital.com/sitemap.xml`

The sitemap was then examined:

```
curl -i https://medirozahospital.com/sitemap.xml
```

The sitemap response is shown below.

```
Sitemap: https://medirozahospital.com/sitemap.xml

(prabhat@prabhat)-[~]
$ curl -i https://medirozahospital.com/sitemap.xml
HTTP/2 200
content-type: application/xml
last-modified: Fri, 04 Sep 2026 02:03:53 GMT
accept-ranges: bytes
content-length: 391
date: Sat, 03 Oct 2026 11:55:58 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

<?xml version="1.0" encoding="UTF-8"?>
<!-- sitemap.xml -->
<urlset xmlns="http://www.sitemaps.org/schemas/sitemap/0.9">
  <url><loc>https://medirozahospital.com/index.html</loc></url>
  <url><loc>https://medirozahospital.com/about.html</loc></url>
  <url><loc>https://medirozahospital.com/doctors.html</loc></url>
  <url><loc>https://medirozahospital.com/contact.html</loc></url>
</urlset>

(prabhat@prabhat)-[~]
$
```

Figure 2: Sitemap discovered during reconnaissance

The sitemap contained:

- /index.html
- /about.html
- /doctors.html
- /contact.html

An important observation was that the sitemap did not contain /patient/, /staff/, or /old/, even though these paths were disclosed through robots.txt.

This provided three additional areas for investigation.

5 Authentication Testing

The /patient/ directory led to the patient login functionality.

The login interface is shown below.

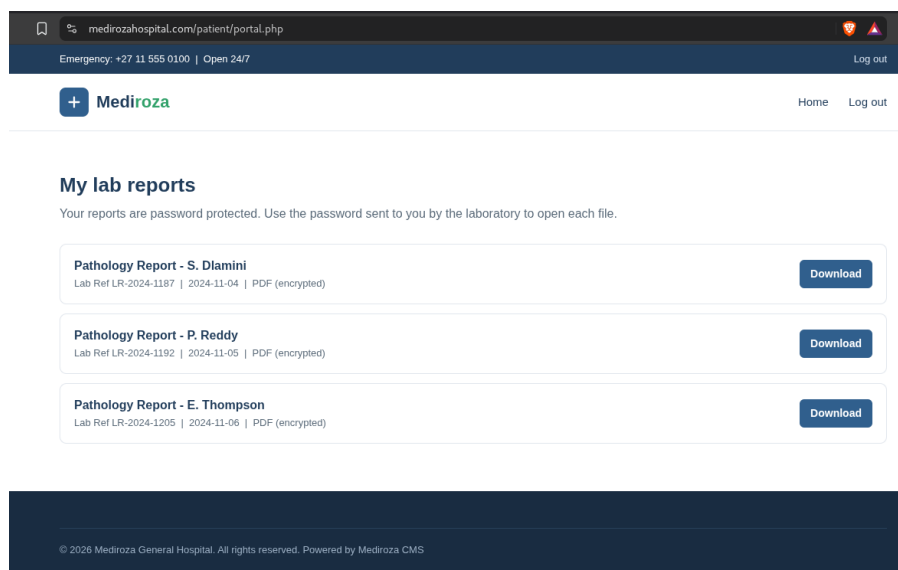


Figure 3: Patient portal login interface

During testing of the login page, different responses were returned for different usernames. This behavior allowed valid usernames to be distinguished from invalid usernames.

5.1 Finding 1 – Username Enumeration

Location: /patient/login.php

Risk: MEDIUM

Description

The application revealed whether a username existed through its authentication error messages. This information could help an attacker identify valid accounts before attempting further attacks.

Impact

Username enumeration reduces the uncertainty around valid accounts and can make subsequent authentication attacks easier.

Recommendation

The application should return the same generic message for both invalid usernames and invalid passwords.

For example:

Invalid username or password.

The application should not reveal which authentication component failed.

6 SQL Injection and Authentication Bypass

Further testing of the login input produced a database error when specially crafted input was supplied.

The response exposed a `mysqli_query()` SQL syntax error. This indicated that user-controlled input was reaching the SQL layer without appropriate protection.

The authorized laboratory exercise subsequently demonstrated that this behavior could be used to bypass the authentication mechanism.

6.1 Finding 2 – SQL Injection / Authentication Bypass

Location: `/patient/login.php`

Risk: **CRITICAL**

Description

The login mechanism was vulnerable to SQL injection.

The application incorporated user-controlled input into a database query without appropriate parameterization.

The vulnerability allowed the authentication logic to be altered and the login process to be bypassed within the authorized lab.

Impact

Successful exploitation could allow an attacker to bypass normal authentication without knowing the legitimate user's password.

Recommendation

The application should:

- Use prepared statements.
- Use parameterized SQL queries.

- Validate input on the server side.
- Avoid directly concatenating user input into SQL statements.
- Prevent database errors from being displayed to users.

7 Patient Reports

After the authentication bypass demonstrated in the authorized lab, the patient portal displayed three reports:

- patient_report_1.pdf
- patient_report_2.pdf
- patient_report_3.pdf

7.1 Finding 3 – Patient Report Access

Location: /patient/reports/

Risk: HIGH

Description

Following the authentication bypass, patient reports became accessible through the patient portal.

Because patient reports can contain sensitive medical information, strong authentication and authorization controls are required.

Impact

An authentication weakness can therefore result in access to protected documents.

Recommendation

Patient documents should not be stored directly in a publicly accessible web directory.

Every document request should verify:

1. Whether the user is authenticated.
2. Whether the authenticated user is authorized to access the requested document.

8 PDF Password Analysis

The reports were password protected.

As part of the authorized laboratory exercise, the PDFs were tested against the supplied password wordlists.

The documented results were:

Report	Result	Risk
patient_report_1.pdf	123456	High
patient_report_2.pdf	password	High
patient_report_3.pdf	!@\$%^&	High

Table 1: Password recovery results from the authorized lab

8.1 Finding 4 – Weak PDF Passwords

Location: Patient PDF reports

Risk: **HIGH**

Description

The passwords protecting the supplied PDF reports were weak enough to be recovered using password wordlists.

Impact

If an encrypted document is obtained by an unauthorized party, weak passwords may provide insufficient protection.

Recommendation

Use strong, unique and randomly generated passwords where PDF encryption is required.

Avoid passwords based on:

- Common passwords
- Usernames
- Dates
- Organization names
- Predictable patterns

9 PDF Metadata Analysis

After creating an unlocked copy of the third report, the PDF metadata was examined using ExifTool:

```
/usr/bin/exiftool report3_open.pdf
```

The metadata output is shown below.

```
<url><loc>https://medirozahospital.com/about.html</loc></url>
<url><loc>https://medirozahospital.com/doctors.html</loc></url>
<url><loc>https://medirozahospital.com/contact.html</loc></url>
</urlset>

(prabhat@prabhat)-[~]
$ cd ~/mediroza-pentest
/usr/bin/exiftool report3_open.pdf
ExifTool Version Number      : 13.55
File Name                    : report3_open.pdf
Directory                   : .
File Size                   : 2.9 kB
File Modification Date/Time  : 2026:10:03 17:07:05+05:30
File Access Date/Time       : 2026:10:03 17:07:05+05:30
File Inode Change Date/Time  : 2026:10:03 17:07:05+05:30
File Permissions             : -rw-rw-r--
File Type                   : PDF
File Type Extension         : pdf
MIME Type                   : application/pdf
PDF Version                 : 1.4
Linearized                  : No
Author                     : j.malik
Comments                    : DB backup moved to /old before site migrat
Creator                    : Mediroza CMS 1.4.2
Keywords                   : pathology, patient report
Producer                   : Mediroza Lab Reporting Module
Subject                    : Full Blood Count
Title                      : Pathology Report - E. Thompson
Page Count                 : 1

(prabhat@prabhat)-[~/mediroza-pentest]
$
```

Figure 4: PDF metadata identified using ExifTool

Several relevant metadata fields were identified, including:

- Author
- Comments
- Creator
- Producer

The metadata revealed information about the application as well as an internal clue concerning the location of a database backup.

9.1 Finding 5 – Sensitive PDF Metadata

Location: patient_report_3.pdf

Risk: MEDIUM

Description

The PDF contained internal metadata that would not normally be necessary for a document distributed to a patient.

The comments field was particularly useful because it referenced a database backup located in the `/old/` directory.

Impact

Document metadata can disclose:

- Software versions
- Internal usernames
- Application components
- Internal operational information

Recommendation

Remove unnecessary metadata before distributing documents.

The laboratory exercise demonstrated metadata removal using:

```
exiftool -all= filename.pdf
```

10 Investigation of the `/old/` Directory

The earlier reconnaissance had already identified the `/old/` directory.

The PDF metadata provided an additional reason to investigate this location.

The directory exposed a directory listing containing a historical database backup.

The exposed directory listing is shown below.

```
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital : internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table `staff`
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011081',130000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2019-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132083',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198089',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209091',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220092',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231093',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242094',118000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253095',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264096',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275097',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286098',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297099',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308091',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319092',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330093',21000,'2019-11-05');
UNLOCK TABLES;

--
-- Table structure for table `shareholders`
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,

```

Figure 5: Exposed /old/ directory listing

The backup was downloadable without authentication within the authorized laboratory environment.

10.1 Finding 6 – Exposed Legacy Backup

Location: /old/

Risk: **CRITICAL**

Description

A historical database backup was stored inside a publicly accessible web directory.

Directory listing was enabled, making the backup file visible.

Impact

A publicly accessible database backup may expose:

- Database structure
- Application information

- Personal information
- Credentials or secrets
- Historical organizational information

Recommendation

- Remove obsolete backups from the web root.
- Store backups outside publicly accessible directories.
- Disable directory listing.
- Apply appropriate access controls.
- Review legacy directories regularly.

11 Database Backup Analysis

The exposed SQL backup contained database structures and records.

The **staff** table contained fields including:

- Full name
- Job title
- Department
- Email
- Phone
- National ID
- Monthly salary
- Date joined

The **shareholders** table contained:

- Shareholder name
- Share percentage
- Shares held
- Share class

The assessment therefore demonstrated that the exposed backup was not simply an empty or obsolete database structure. It contained organizational and personal information.

11.1 Finding 7 – Confidential Information Exposure

Location:

/old/mediroza_db_backup_2019.sql

Risk: CRITICAL

Description

The publicly accessible SQL backup exposed confidential staff and shareholder information.

Impact

Unauthorized access to the backup could expose sensitive personal and organizational information.

Recommendation

The backup should be removed from public access.

The organization should also:

- Store backups outside the web root.
- Restrict backup access.
- Encrypt sensitive backups.
- Establish backup retention policies.
- Review historical backups for similar exposure.

12 Evidence Correlation

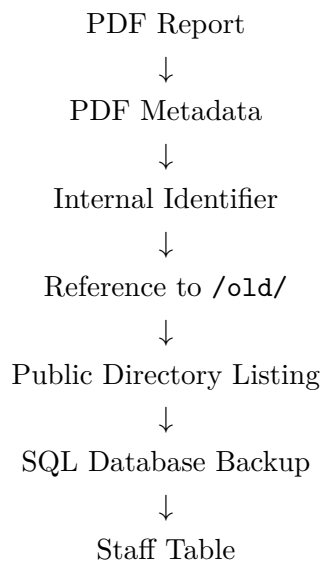
One of the most important parts of the assessment was connecting findings discovered at different stages.

The PDF metadata contained information identifying an internal author identifier.

The same metadata contained a comment referencing the database backup.

The exposed SQL backup contained a corresponding staff record associated with the identifier.

The resulting evidence chain was:



This demonstrated how information found during one stage of a penetration test can provide the clue needed to investigate another part of the application.

13 Findings Summary

#	Finding	Location	Risk
1	Username enumeration	/patient/login.php	MEDIUM
2	SQL injection / authentication bypass	/patient/login.php	CRITICAL
3	Patient reports accessible after authentication bypass	/patient/reports/	HIGH
4	Weak PDF passwords	Patient PDF reports	HIGH
5	Sensitive PDF metadata	patient_report_3.pdf	MEDIUM
6	Exposed legacy backup / directory listing	/old/	CRITICAL
7	Confidential staff and shareholder information	SQL database backup	CRITICAL

14 Recommendations and Remediation

14.1 Authentication

The login mechanism should use prepared statements or parameterized queries and should never construct SQL queries using raw user input.

14.2 Authentication Error Messages

The application should return the same generic authentication error for invalid usernames and passwords.

14.3 Patient Documents

Patient documents should be stored outside the public web root and served only after appropriate authentication and authorization checks.

14.4 PDF Passwords

Strong and unique passwords should be used for encrypted documents.

Common and predictable passwords should be avoided.

14.5 PDF Metadata

Unnecessary metadata should be removed before documents are distributed externally.

14.6 Directory Listing and Backups

Directory listing should be disabled on production systems.

Database backups should never be stored inside publicly accessible web directories.

Legacy backups should be removed or moved to a properly secured backup location.

15 Lessons Learned

The most important lesson from this assessment was the importance of following evidence instead of simply running a predefined list of commands.

The investigation developed progressively:

Reconnaissance → Clue → Hypothesis → Test → Evidence → Correlation

For example, the /old/ directory was initially discovered during reconnaissance.

Later, PDF metadata provided an independent clue pointing towards the same directory.

Investigating that clue then revealed the exposed database backup.

This demonstrated that penetration testing is not only about knowing security tools and payloads.

It also requires the ability to interpret results, form hypotheses, connect seemingly unrelated observations, and decide what to investigate next.

16 Conclusion

The assessment identified several security weaknesses affecting authentication, document protection, metadata handling, and legacy file management.

The most significant issue was the exposure of a historical database backup through a publicly accessible directory.

The backup contained confidential organizational information and demonstrated the potential impact of poor legacy-file management.

The authentication weaknesses were also significant because they could provide access to protected patient reports.

Overall, the assessment demonstrated how multiple weaknesses can combine into a larger security issue.

Proper input handling, authentication, authorization, document protection, metadata sanitization, and secure backup management would significantly reduce the identified risks.

17 Authorization and Responsible Testing

This assessment was conducted as part of an authorized educational security-testing exercise.

The techniques documented in this report are intended only for systems where explicit authorization has been provided by the owner.

Sensitive information discovered during testing should not be published unnecessarily.

Any public version of this report should redact personal information, medical information, national identification numbers, telephone numbers, email addresses, credentials, and other sensitive data.